Week 2 - Reconnaissance and OSINT

6COSC019W

Dr Ayman El Hajjar

Academic Year: 2025-2026

lab environment

- In this lab, you will need both the **Kali VM** and the **OWASP VM**.
- Before you start the lab, you must set up the lab environment as per the instructions in **Lab1**, depending on whether you are using your own machine or a lab computer.
- Below is a summary of the steps. Read the Lab Environment Setup document if you are stuck.
  - From inside VMware Delete all existing virtual machines to ensure you start from a **clean state**.
  - Browse to the C:\VirtualMachines folder.
  - You should see the .7z files for Kali and OWASP.
  - **Please do not delete any .7z files may be present**. They are for other modules.
  - It is safe to delete folders inside C:\VirtualMachines. These are from previous deployments.
  - Extract each file using 7-Zip and select **Extract here**.
  - Add the virtual machines to VirtualBox.
  - Check that the network settings are correct.
  - Use **NAT** if the activity requires Internet access.
  - Use **Host Only Network** if the activity requires interaction with OWASP.
- **Make sure you run the studentid script before starting the lab**

```
./studentid.sh
```

- Download the module repository. It contains files needed later in the lab.
  - Open a terminal and navigate to the Desktop to store all files.

```
cd ~/Desktop/
```

```
git clone https://github.com/azelhajjar/6COSC019W.git
```

© University of Westminster 2025/26

1 Introduction & Lab objectives

- Passive reconnaissance gathers information about a target without direct interaction to avoid detection.
- Some reconnaissance methods can become active if aggressive scans are used. In this lab, only passive low profile scans are conducted.
- OSINT involves searching for publicly available information online.
- The activity focuses only on publicly accessible data.
- Different tools can be used to organise and automate OSINT tasks.
- The OSINT phase can take a long time and prepares for later attack stages.
- The main benefit is collecting useful information for future attacks, including building wordlists.
- Typical information includes:
  - **Domains and DNS** Registered domains, subdomains, DNS records, and WHOIS data.
  - **IP and Network** Public IP ranges, ISP, and Autonomous System details.
  - **Organisation** Staff, contacts, partners, and office locations.
  - **Email** Public addresses and common email formats.
  - **Technology** Web servers, CMS, frameworks, and software versions.
  - **Online Presence** Social media, forums, and GitHub content.
  - **Vulnerabilities** Known CVEs and misconfigurations.
  - **Physical Security** Public location and building details.
  - **Human Factors** Phishing and social engineering targets.
- This lab assumes you have completed the **Introduction to Linux Lab**.
- After completing this lab, you should be able to:
  - Explain why reconnaissance and OSINT are used.
  - Explain how poor reconnaissance can be detected.

Assignment

After completing this lab, you should be able to answer all the assessment questions in **Section 1: OSINT and Passive Reconnaissance**.

2 DNS reconnaissance

What is DNS reconnaissance

- DNS reconnaissance is the process of gathering publicly available DNS information such as domain names, IP addresses, and DNS servers.
  - This information can help identify potential attack vectors.
- **Note:** Although these commands use public information, you must not run them on any website without permission.

- In this section, you will gather information about public DNS records.
  - This is a form of OSINT.
  - It can reveal useful technical details.
- Different tools often return similar results in different formats.
  - Using multiple tools can reveal extra information.

2.1 WHOIS

- WHOIS is a protocol used to query domain and IP registration databases.
  - It provides details about domain owners, registrars, and contacts.
- Both hackers and ethical hackers use WHOIS during reconnaissance.
  - It helps build a digital profile of a target.
- You can use WHOIS in two ways:
  - Via an online database such as https://who.is/
  - Using the **whois** command.

```
whois cwscenario.uk
```

```
whois westminster.ac.uk
```

- Compare the results.
  - Some domains use privacy protection.
  - Public institutions often expose more information.

2.2 DNS Enumeration

What is DNS enumeration

- DNS enumeration locates DNS servers and records.
  - It gathers details such as hostnames and IP addresses.
- **Unlike DNS reconnaissance, DNS enumeration is more intrusive.**
  - It actively queries DNS servers.

This activity extracts deeper DNS information. It is more aggressive than reconnaissance.

DNS enumeration speed

An aggressive DNS enumeration will be slow. You may want to try the tools quickly in the lab and run them later in your own time.

Kali provides several DNS tools. They are in the Information Gathering menu. These tools can reveal:

- Host records
- Name servers
- Mail servers
- Subdomains

We will focus on the **dnsenum** tool.

- Running dnsenum without options shows available parameters.

```
dnsenum
```

A basic scan queries for the cwscenario.uk domain will return:

```
dnsenum cwscenario.uk
```

- A records
- NS records
- MX records

You may see a **network is unreachable** message when dnsenum attempts a zone transfer (AXFR).

- This happens because most DNS servers block zone transfers for security reasons.
- It does not mean you have done anything wrong.

↳ The server is simply refusing the request.

We can do a more aggressive scan using one of the several parameters available for dnsenum

↳ The `--enum` option performs a more aggressive scan.

```
dnsenum --enum cwscenario.uk
```

↳ This performs WHOIS queries only.

```
dnsenum --whois cwscenario.uk
```

↳ Increasing threads speeds up scanning.

```
dnsenum --threads 15 cwscenario.uk
```

↳ This searches for 5 subdomains.

```
dnsenum --scrap 5 cwscenario.uk
```

↳ Verbose mode shows detailed output.

```
dnsenum -v cwscenario.uk
```

↳ Combining options improves results and increases the scan time.

```
dnsenum --scrap 10 --recursion --subfile subdomains.txt --threads
20 -v cwscenario.uk
```

There are several tools that do similar task to dnsenum. Some are pre-installed on Kali

↳ Another available tool is **dnsmap**.

```
dnsmap cwscenario.uk
```

↳ Another tool is **dnsrecon**.

```
dnsrecon -d cwscenario.uk
```

Each tool uses its own wordlist. They search for subdomains. Attackers often create custom wordlists.

↳ These are based on the target organisation.

↳ The dnsenum wordlist is **dns.txt**. It contains 1505 entries.

↳ The dnsmap wordlist is **wordlist_TLAs.txt**. It contains 17576 entries.

For efficiency, we will use our own wordlist. You should already have the module repository cloned. Use the module wordlist to search for more subdomains.

```
dnsenum -f ~/Desktop/6COSC019W/modulewordlist.lst cwscenario.uk
```

```
dnsmap cwscenario.uk -w ~/Desktop/6COSC019W/modulewordlist.lst
```

Figure 2.1: whois response for cwscenario

2.3 dig

The dig command

- The **dig** command is used to query specific DNS records for a domain.
- It helps you understand how a domain is configured.

- We will use the dig command on the cwscenario.uk domain.

```
dig cwscenario.uk
```

- This returns the A record, which maps the domain name to an IP address.

  ```
  dig cwscenario.uk A
  ```

  ↳ You can also use the short format. The **+short** option provides cleaner output.

  ```
  dig cwscenario.uk A +short
  ```

- To query the name servers, use the NS record.

  ```
  dig cwscenario.uk NS
  ```

  ↳ Or use the short format.

  ```
  dig cwscenario.uk NS +short
  ```

- To query the mail servers, use the MX record.

  ```
  dig cwscenario.uk MX
  ```

  ↳ Or use the short format.

  ```
  dig cwscenario.uk MX +short
  ```

- To query domain metadata, use the TXT record.

```
dig cwscenario.uk TXT
```

↳ Or use the short format.

```
dig cwscenario.uk TXT +short
```

2.4 Amass

The Amass tool

Amass is an information gathering tool used for passive reconnaissance on domain names.

Amass can collect subdomains, DNS data, and network information without using API keys.

We will use Amass in **passive mode** to avoid active scanning.

Type **amass -h** in a terminal to view all available options.

We will use **enum** for enumeration, **-passive** for passive mode, and **-d** to specify the domain.

```
amass enum -passive -d cwscenario.uk
```

The output will display discovered subdomains and related information.

You can save the output to a file using the **-o** option.

```
amass enum -passive -d cwscenario.uk -o amass.txt
```

Amass may also return ASN and IP range information.

Review the results and note any useful subdomains for later activities.

3 Open Source Intelligence OSINT

OSINT activities

You are conducting this assessment on Live websites. This is called passive reconnaissance.

You can see what type of sources can be used in OSINT investigation using the OSINT Framework

Have a look at this large collection of OSINT tools and methods on github Awesome OSINT . it will give you a sense of how long and how much in depth one can spend conducting OSINT activities.

We are using **cwscenario.uk** for the OSINT activities.

3.1 SpiderFoot

- Another OSINT tool you should explore is SpiderFoot.
- SpiderFoot is pre-installed on Kali.
- To start it, open a terminal and specify the server address and port number.

```
spiderfoot -l 127.0.0.1:5001
```

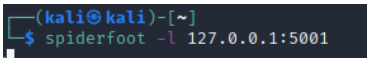


Figure 3.1: Starting SpiderFoot on localhost port 5001

- SpiderFoot is module based and some modules require API keys.
  - Some modules will not work without API keys.
  - Other modules use API keys only to speed up scanning.
- Check the **Website guide** for more information. **Ignore the installation section**.
  - [1] While SpiderFoot is running on the terminal, open a browser and go to 127.0.0.1:5001.
  - [2] Click on "New Scan".
  - [3] Give the scan a name.
  - [4] Enter either a domain name or an IP address. We will use **cwscenario.uk**
  - For now, we will only perform OSINT activities at this stage.
  - [5] Choose **Passive Scan**
  - [6] Press on **Run Scan Now**
- Wait for the scan to complete.
- Results will appear gradually.
- Once finished, review the results.
  - Domain name information
  - DNS TXT records
  - BGP AS membership (ASN)
  - Physical server location

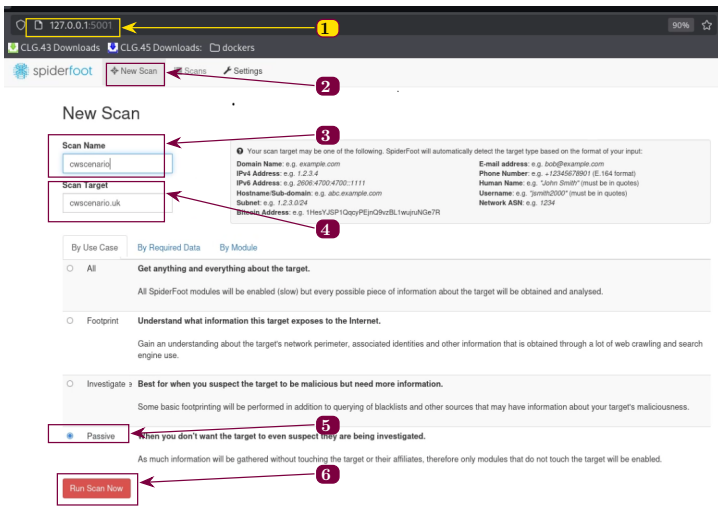


Figure 3.2: A passive scan on cwscenario.uk.

4 Information gathering

Network settings for remaining activities

- The remaining activities require the OWASP VM to be started.
- Check the Lab Environment Setup document for instructions.
- Below is a summary of the required network settings for NAT and Host-Only.
- For the Kali VM, switch between **Host-Only Adapter** and **NAT** depending on the activity.
  - If probing **cwscenario.uk**, you must use **NAT**.
  - If probing **192.168.144.129 (or your IP)**, you must use **Host-Only Adapter** as shown in Fig.4.2.
- Change the adapter by clicking **Settings** > **Network** and selecting the required adapter as shown in Fig.4.1a.
- Select **NAT** to connect to the Internet as shown in Fig.4.1b.

```
sudo ifconfig eth0 down
```

↳ Disable the network interface.

```
sudo ifconfig eth0 up
```

↳ Enable the network interface.

```
sudo ifconfig eth0
```

↳ Check your IP address.

Select **Host-Only Adapter** to connect to the Host-Only network as shown in Fig.4.1c.

```
sudo ifconfig eth0 down
```

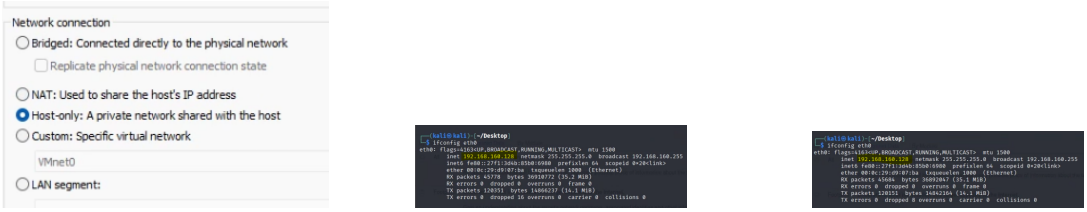
↳ Disable the network interface.

```
sudo ifconfig eth0 up
```

↳ Enable the network interface.

```
sudo ifconfig eth0
```

↳ Check your IP address. Compare Figure.4.1a and Figure.4.1b. The Host-Only network prefix is **192.168.144**.



(a) Changing Network attachment

(b) Kali connected to the Internet via NAT

(c) Kali connected to the Host-Only adapter

Figure 4.1: Kali Network settings

The OWASP VM must be connected to the **Host-Only Adapter** as shown in Fig.4.2.

```
ifconfig
```

In this environment, the OWASP VM was assigned the IP address **192.168.144.129** as shown in Fig.4.2.

Check your own IP address. It may be different.

```
sudo dhclient
```

If you change the network adapter after starting the OWASP VM, the IP address will not update automatically.

You can also reset the interface to request a new IP.

```
sudo ifconfig eth0 down
```

↳ Disable the network interface.

```
sudo ifconfig eth0 up
```

↳ Enable the network interface.

```
sudo ifconfig eth0
```

↳ Check your IP address.

```
root@owaspbwa:~# ifconfig eth0
eth0      Link encap:Ethernet  HWaddr 00:0c:29:8e:fb:6e
          inet addr:192.168.144.129  Bcast:192.168.144.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe8e:fb6e/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:73 errors:0 dropped:0 overruns:0 frame:0
          TX packets:91 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:11942 (11.9 KB)  TX bytes:14613 (14.6 KB)
          Interrupt:18 Base address:0x2000
```

Figure 4.2: OWASP connected to the Host-Only adapter

4.1 Information gathering from simply looking at code

Why looking at the source code?

- Looking at a web page source code helps you understand the logic, spot obvious issues, and compare changes after testing.
- It can also reveal information developers forgot to remove, such as usernames, passwords, and hidden files or folders.

Your wordlists

- Ask any penetration tester about the most important tool, and the answer is usually wordlists.
- You will create two files in your home folder: one for users and one for passwords.

```
cd ~
touch users.lst
```

↳ This creates a file called **users.lst**.

```
touch passwords.lst
```

↳ This creates a file called **passwords.lst**.

- Add every discovered username to **users.lst**.
- Add every possible password to **passwords.lst**.
- Examples:

```
echo 'root' » users.lst
echo 'owaspbwa' » passwords.lst
```

- While Kali is connected to the **Host-Only Adapter**, open a browser and go to the OWASP VM IP address.

↳ In this example, the IP address is **192.168.144.129**.

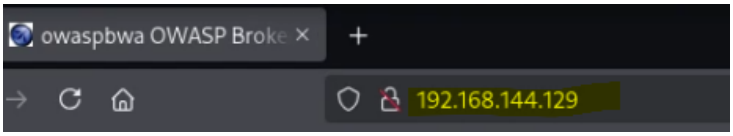


Figure 4.3: OWASP Webpage

- Right click on the page and select **View Page Source**.
- **You can learn a lot by reading the source code.**
- Some applications store usernames and passwords directly in the code.
- Add any discovered credentials to your wordlists.

```
echo 'user' » users.lst
```

  - This adds **user** to **users.lst**.

```
echo 'user' » passwords.lst
```

  - This adds **user** to **passwords.lst**.
- **Update both wordlists with all usernames and passwords you find.**
- When finished, switch Kali to **NAT** mode.
- Open a browser and go to **cwscenario.uk**.
- Repeat the same source code inspection.
  - Look for server information.
  - Add potential usernames to **users.lst**.
  - Add potential passwords to **passwords.lst**.
- While Kali is connected to **NAT**:
  - Open a browser and go to **cwscenario.uk**.
  - Right click and select **View Page Source**.
  - Look for the platform version information.
  - Search for the **generator** meta tag.
  - This shows the WordPress version used by the website.
- Knowing the platform version allows you to check for known vulnerabilities.
- You can search the CVE database for reported issues.
- The current WordPress version is recent and has no known vulnerabilities.

- Older versions may contain multiple CVEs.

4.2 Taking advantage of robots.txt

How robots.txt works

- robots.txt is a file placed at the root of a website.
- It provides instructions to web crawlers about which files or directories they should or should not index.
- From an attacker perspective, it can reveal hidden areas of the website.
- This approach is called **security through obscurity**.
- Users and attackers can still access these locations.

- Some website pages and directories are not linked to the main interface.
- Examples include login pages or CMS administration panels.
- Finding these expands the testing surface.
- We will use **robots.txt** to discover hidden files and directories.
- **NOTE** Finding robots.txt is passive reconnaissance. Visiting the listed locations is active reconnaissance.
- While Kali is connected to the **Host-Only Adapter**:
  - Open a browser and go to **192.168.144.129**.
  - Add robots.txt to the URL.
  - **http://192.168.144.129/robots.txt**
  - There is no robots.txt file here.
- Try other applications on the same server.
  - **http://192.168.144.129/vicnum/robots.txt**
  - This robots.txt file blocks two folders: **jotto** and **cgi-bin**.
  - The / at the end means they are directories.
- Browse the listed folders.
  - **http://192.168.144.129/vicnum/cgi-bin/**
  - The **cgi-bin** folder contains Perl scripts for the Vicnum game.
  - **http://192.168.144.129/vicnum/jotto/**
  - The Jotto folder contains a word list file.

- Jotto is a word guessing game.
- This list may contain the game answers.

- Try to find robots.txt files for other applications.
  - bWAPP
  - Joomla
  - tikiwiki
- Record useful information.
  - Add potential usernames to **users.lst**.
  - Add potential passwords to **passwords.lst**.
- Now connect Kali to **NAT** and look for robots.txt information on the cwscenario.uk domain.
  - Open a browser and go to **cwscenario.uk**.
  - Add robots.txt to the URL.
  - **https://cwscenario.uk/robots.txt**
  - Some folders and files are blocked from crawlers.
  - Explore these locations.
- Record useful information again.
  - Add potential usernames to **users.lst**.
  - Add potential passwords to **passwords.lst**.

End notes!

- You have now completed this lab.
- Keep the **users.lst** and **passwords.lst** files.
- You will need them in later labs.
- Make sure you sign out afterwards.